

Incident Response Policy

Document Control

Field	Value
Policy ID	POL-SEC-004
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Management
Classification	Internal

1. Purpose

This policy establishes GlobalTech Manufacturing's approach to preparing for, detecting, responding to, and recovering from information security incidents affecting its IT and Operational Technology (OT)/IoT environments. Its purpose is to minimize the operational, financial, legal, and reputational impact of security incidents; ensure a consistent and timely response across all five countries of operation; and meet obligations under **ISO 27001**, the **GDPR**, and applicable industry-specific and local regulations. This policy follows the incident lifecycle defined in **NIST SP 800-61 Rev. 2**: Preparation → Detection & Analysis → Containment, Eradication & Recovery → Post-Incident Activity.

2. Scope

2.1 Applicability

This policy applies to:

- ☒ All employees
- ☒ Contractors and consultants
- ☒ Third-party vendors and managed service providers

- ☑ All GlobalTech Manufacturing sites and subsidiaries in all 5 countries of operation

2.2 Systems/Assets Covered

This policy covers all information systems, networks, and data owned or operated by GlobalTech Manufacturing, including corporate IT systems, cloud services, and **Operational Technology (OT) and Industrial IoT systems** used in manufacturing (e.g., programmable logic controllers, SCADA systems, connected factory-floor sensors and equipment). It applies to incidents affecting confidentiality, integrity, or availability of these systems, as well as incidents involving personal data subject to GDPR.

2.3 Exclusions

Physical security incidents with no information security component (e.g., a simple facility break-in with no system access) are handled under the separate Physical Security Policy, though any incident that also involves or may involve system or data access falls under this policy.

3. Policy Statements

3.1 Incident Classification

All security incidents must be classified by severity immediately upon confirmation, using the criteria below. Classification may be escalated or de-escalated as new information becomes available during the response.

Severity	Description	Response Time (Initial Response)	Examples
Critical	Incident causes, or is likely to cause, significant disruption to manufacturing/OT operations, a confirmed large-scale breach of personal or sensitive data, or an imminent safety risk. Requires immediate executive involvement.	Within 30 minutes, 24/7	Ransomware affecting OT/production systems; confirmed large-scale customer or employee data breach; safety-impacting compromise of industrial control systems; active attacker with domain-level access

High	Incident significantly impacts a business function or a limited set of systems, with realistic potential to escalate to Critical if not contained quickly.	Within 1 hour, 24/7	Malware outbreak contained to a single site/segment; confirmed unauthorized access to a sensitive system without evidence of mass data exfiltration; targeted phishing compromise of a privileged account
Medium	Incident affects a limited number of users or a non-critical system, with contained or low likelihood of further impact.	Within 4 business hours	Isolated malware on a single workstation; policy violation involving potential data mishandling; suspicious activity requiring investigation but no confirmed compromise
Low	Minor incident or a security event that does not indicate compromise but should be logged and reviewed.	Within 1 business day	Single failed intrusion attempt blocked by existing controls; minor policy violation; false-positive alert requiring confirmation

3.2 Incident Response Team

The Incident Response Team (IRT) is a cross-functional team activated according to incident severity. Roles are defined in Section 4.

3.3 Detection and Reporting

Requirements:

- Incidents may be detected through automated monitoring (SIEM, endpoint detection and response, OT/IoT network monitoring, intrusion detection systems), employee reports, third-party notification, or vendor/customer reports
- Any employee, contractor, or vendor who suspects a security incident must report it immediately to the IT Security Team via the 24/7 Security Operations Center (SOC) hotline, the security incident reporting portal, or email to andrei@cyberdlh.lu
- Initial reports should include, where known: date/time first observed, systems or data potentially affected, a description of what was observed, any actions already taken, and

the reporter's contact information

- Upon receipt, the SOC or on-call Security Analyst performs an **initial assessment** within the response time defined in Section 3.1, to confirm whether an actual incident has occurred, assign a preliminary severity classification, and determine whether IRT activation is required
- OT/IoT-related alerts follow the same reporting path but must also notify the Plant/Site Operations Manager immediately, given potential safety and production impact

3.4 Response Procedures

Response follows the NIST SP 800-61 Rev. 2 lifecycle: Preparation, Detection & Analysis, Containment/Eradication/Recovery, and Post-Incident Activity.

Preparation

- Maintain up-to-date incident response playbooks (including OT/IoT-specific playbooks), contact lists, and tooling
- Conduct incident response tabletop exercises at least annually
- Maintain current asset inventories for both IT and OT/IoT environments to support rapid impact assessment

Detection & Analysis

- Correlate alerts across IT and OT monitoring tools to determine scope and confirm the incident
- Assign or confirm severity classification per Section 3.1
- Activate the Incident Response Team according to severity

Containment

- *Short-term containment*: Immediately limit the spread or impact of the incident (e.g., isolate affected hosts or network segments, disable compromised accounts, and — for OT/IoT — apply containment methods that avoid unsafe shutdowns of production or safety systems without Operations sign-off)
- *Evidence preservation*: Before making changes that could destroy evidence, capture forensic images, logs, memory captures, and network traffic where feasible, per Section 6
- *Long-term containment*: Apply temporary fixes (e.g., patches, firewall rules, credential resets) to allow continued business operation while eradication is planned

Eradication

- Identify the root cause of the incident
- Remove the threat entirely from the environment (e.g., malware removal, closing exploited vulnerabilities, revoking compromised credentials and certificates)
- Validate that eradication is complete through scanning, log review, and where relevant, third-party forensic confirmation before proceeding to recovery

Recovery

- Restore affected systems from known-good backups or clean rebuilds, prioritizing safety and production-critical OT systems in coordination with Site Operations
- Conduct testing to confirm systems are functioning normally and securely before returning them to production
- Apply enhanced monitoring to affected systems for a defined period following recovery to detect any recurrence

3.5 Communication Plan

Communication during an incident must follow the Communication Plan defined in Section 5 and the companion Communication Plan document, ensuring stakeholders are notified appropriately and regulatory deadlines (including the GDPR's 72-hour breach notification requirement) are met.

3.6 Evidence Handling

All evidence collected during an incident must be handled in accordance with the chain-of-custody and preservation requirements defined in Section 6.

3.7 Post-Incident Activities

Every Critical and High severity incident, and any Medium incident at the IRT's discretion, requires a formal post-incident review and lessons-learned process as defined in Section 7.

4. Roles and Responsibilities

Role	Responsibilities
Incident Response Manager	Leads the IRT during an active incident, owns the decision to escalate/de-escalate severity, coordinates across functions, and ensures the incident timeline and actions are documented

Security Analysts (SOC)	Perform detection, initial triage, technical investigation, containment, eradication, and recovery actions; maintain monitoring tools and playbooks
IT Support / Infrastructure Teams	Execute technical containment and recovery actions on affected systems (servers, endpoints, network); support OT/IT coordination for manufacturing systems
OT/Site Operations Manager	Advises on safe containment and recovery actions for OT/IoT systems, authorizes any action affecting production or safety systems, coordinates with plant staff
Legal Counsel	Assesses legal exposure, attorney-client privilege considerations, contractual notification obligations, and regulatory notification requirements (including GDPR Article 33); coordinates with external counsel and law enforcement as needed
Data Protection Officer (DPO)	Assesses whether an incident constitutes a personal data breach under GDPR, determines notification obligations to supervisory authorities and data subjects, and documents the assessment
Communications/PR	Prepares and coordinates internal and external communications, including customer, media, and public statements, in coordination with Legal and Executive Sponsor
Executive Sponsor	Provides executive authority for major decisions (e.g., production shutdowns, public disclosure, ransom decisions), approves resource allocation, and serves as the point of accountability to the Board
Human Resources	Supports incidents involving employee misconduct, insider threats, or personnel-related communications
All Employees, Contractors, and Vendors	Report suspected incidents promptly and cooperate with the IRT during investigation and response

5. Communication Plan

Stakeholder	When to Notify	Method
-------------	----------------	--------

Executive Management / Executive Sponsor	Immediately for Critical incidents; within 4 hours for High severity; per standard reporting for Medium/Low	Phone/SMS call-tree for Critical; secure email/incident management platform otherwise
Legal Counsel	Immediately upon confirmation of any incident involving personal data, potential regulatory exposure, litigation risk, or law enforcement interest	Phone call followed by secure email; engaged directly in IRT activation for Critical/High incidents
Data Protection Officer	Immediately upon any suspicion of a personal data breach, to begin the GDPR assessment clock	Phone call and secure email; joins IRT for any incident with potential data breach implications
Regulators (e.g., data protection authorities)	Within 72 hours of becoming aware of a qualifying personal data breach, per GDPR Article 33; per applicable timelines for other industry-specific regulators	Formal notification via the relevant supervisory authority's official reporting channel, prepared by Legal/DPO
Affected Data Subjects / Customers	Without undue delay, where the breach is likely to result in a high risk to the rights and freedoms of individuals (GDPR Article 34), or as required by contract	Direct notification (email/letter) coordinated by Communications and Legal; public notice only where direct contact is not feasible
Affected Employees (Internal Users)	As soon as practical once containment actions are underway if action is required of them (e.g., password reset)	Internal email, intranet notice, or direct manager communication
Law Enforcement	Where the incident may constitute a crime (e.g., ransomware, fraud, theft of trade secrets), as determined by Legal Counsel	Formal report via Legal Counsel and/or CISO to relevant national law enforcement/cyber authority
Insurance Provider (Cyber Insurance)	As soon as practical for any incident that may trigger a claim, and always for Critical incidents	Formal notification per policy terms, coordinated by Legal/Finance

Vendors/Partners with Shared Systems	As soon as containment allows, if the incident may affect shared/connected systems	Direct account-manager or security contact notification
--------------------------------------	--	---

Full detail is maintained in the companion **Incident Communication Plan** document.

6. Evidence Handling

6.1 Chain of Custody

All physical and digital evidence collected during an incident must be logged using a chain-of-custody form recording who collected it, when, how, and every subsequent transfer of custody. Evidence must be stored in a manner that prevents tampering (e.g., write-protected storage, restricted-access evidence locker).

6.2 Evidence Preservation

Requirements:

- Where feasible, forensic images, memory captures, and relevant logs must be collected before affected systems are modified, rebooted, or rebuilt
- OT/IoT evidence collection must be coordinated with Site Operations to avoid unsafe interruption of production or safety systems; where live collection is not possible, the rationale must be documented
- Logs relevant to an incident must be preserved beyond standard retention periods for the duration of the investigation and any related legal or regulatory process
- Original evidence must not be analyzed directly where possible; analysis should be performed on verified forensic copies

6.3 Documentation Requirements

All incident response actions must be logged in the incident timeline, including detection time, each response action taken, who took it, and the outcome, using the Incident Report Template referenced in Section 7.

7. Post-Incident Activities

7.1 Lessons Learned Process

For all Critical and High severity incidents (and Medium incidents at the IRT's discretion), a post-incident review meeting must be held within 10 business days of incident closure,

including all IRT members involved. The review must identify what worked well, what did not, root cause, and specific, assigned remediation actions with due dates.

7.2 Report Requirements

A final Incident Report must be completed using the standard Incident Report Template, reviewed by the Incident Response Manager and CISO, and retained per the company's records retention schedule. Reports supporting regulatory notifications must be retained for the period required by the relevant regulation (e.g., GDPR accountability requirements).

8. Compliance

8.1 Monitoring

The SOC monitors IT and OT/IoT environments continuously using SIEM, endpoint detection and response, and OT-specific network monitoring tools to detect indicators of potential incidents.

8.2 Reporting

Incidents are reported through the 24/7 SOC hotline, the security incident reporting portal, or email to andrei@cyberdlh.lu, as described in Section 3.3.

8.3 Auditing

This policy, the IRT's performance, and a sample of closed incidents are reviewed at least annually as part of the ISO 27001 internal audit program, with findings reported to Executive Management.

9. Enforcement

9.1 Violations

Failure to report a known or suspected incident, or failure to follow required response procedures, may result in:

- Verbal warning
- Written warning
- Suspension of system access privileges
- Disciplinary action up to and including termination
- Legal action where applicable

9.2 Reporting Violations

Report suspected policy violations to IT Security or Human Resources via the confidential ethics hotline.

10. Exceptions

10.1 Exception Process

Exceptions to this policy require:

1. A written request submitted to the CISO
2. A documented business justification
3. A risk assessment conducted by IT Security
4. Compensating controls where applicable
5. Formal written approval and documentation retained by IT Security

10.2 Exception Duration

All exceptions must have a defined end date and be reviewed quarterly.

11. Definitions

Term	Definition
Incident	An event that actually or potentially jeopardizes the confidentiality, integrity, or availability of an information system or the data it processes, stores, or transmits
Incident Response Team (IRT)	The cross-functional team activated to manage the response to a security incident
OT (Operational Technology)	Hardware and software that detects or causes changes in physical industrial processes, e.g., SCADA and industrial control systems
Chain of Custody	The documented, unbroken record of the collection, control, transfer, and disposition of evidence
Personal Data Breach (GDPR)	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data

Security Operations Center (SOC)	The team and function responsible for continuous monitoring and initial detection/triage of security events
----------------------------------	---

12. Related Documents

- Incident Classification Matrix (companion document)
- Incident Communication Plan (companion document)
- Incident Report Template (companion document)
- Acceptable Use Policy
- Password Policy
- Business Continuity and Disaster Recovery Plan
- OT/IoT Security Standard
- NIST SP 800-61 Rev. 2: Computer Security Incident Handling Guide
- SANS Incident Handler's Handbook
- GDPR Article 33/34: Breach Notification Requirements
- CISA Incident Response Playbooks
- ISO/IEC 27001 Annex A (Incident Management controls)

13. Revision History

Version	Date	Author	Description
1.0	2026-08-19	CISO	Initial release, aligned with NIST SP 800-61 Rev. 2, ISO 27001, and GDPR Article 33/34

14. Acknowledgment

By accessing GlobalTech Manufacturing systems, all employees, contractors, and vendors acknowledge they have read, understood, and agree to comply with this Incident Response Policy.

For formal acknowledgment tracking, use the company's policy acknowledgment system.

End of Policy Document